

Lecture 18 : Information Gathering

(Part 2)

Introduction

In the realm of cybersecurity, effective information gathering is the foundational step for any successful penetration test or security assessment. This lecture delves into active reconnaissance, a method where direct interaction with the target system or network is employed to gather crucial intelligence. Unlike passive methods that rely on publicly available information, active reconnaissance involves direct communication, allowing an attacker or ethical hacker to uncover deeper insights into a target's infrastructure.

Understanding a target's digital footprint, including its domain name system (DNS) configuration, open ports, running services, and operating system details, is paramount. This phase is critical for identifying potential vulnerabilities that could be exploited. By actively probing the network, security professionals can simulate real-world attack scenarios, thereby strengthening defenses and mitigating risks before malicious actors can exploit them.

Core Concepts

Term	Definition	Significance
Active Reconnaissance	A method of information gathering that involves direct interaction with the target system or network to collect data.	Essential for obtaining detailed, real-time information about a target's live infrastructure and potential vulnerabilities.
DNS Enumeration	The process of querying DNS servers to gather information like IP addresses, server names, and functionalities associated with a domain.	Reveals the structure of a target's network, including mail servers and name servers, which can expose entry points.
Zone Transfer	A mechanism where a DNS server transfers a copy of its zone file (containing all DNS	A misconfigured zone transfer can expose a complete map of a domain's internal network to

Term	Definition	Significance
	records for a domain) to another DNS server.	unauthorized parties, a critical security flaw.
Scanning	The act of actively probing a target machine or network to identify vulnerabilities, open ports, running services, and operating systems.	Forms the backbone of vulnerability assessment, allowing identification of exploitable weaknesses before an attack.
Stealth Scan (-sS)	A type of TCP scan that initiates a connection but never completes the three-way handshake, making it less detectable.	Useful for reconnaissance as it attempts to avoid logging by intrusion detection systems, offering a covert way to identify open ports.
TCP Connect Scan (-sT)	A full TCP connection scan that completes the three-way handshake, often gathering more information but being more detectable.	Provides reliable information about open ports and services, though it leaves a clearer footprint on target logs.
UDP Scan (-sU)	A scan specifically designed to assess UDP ports on a target system, expecting replies from closed ports.	Crucial for identifying UDP-based services, which are often overlooked but can harbor vulnerabilities.
ACK Scan (-sA)	A scan used to determine if a TCP port is filtered by a firewall or unfiltered, by sending ACK packets.	Helps in mapping firewall rules and understanding network filtering mechanisms without necessarily determining port state.
Nmap Timing Templates	Predefined settings (T0-T5) in Nmap that control the aggressiveness and speed of a scan.	Allows users to balance scan speed, network impact, and accuracy, adapting to different network conditions and stealth requirements.

Term	Definition	Significance
Packet Fragmentation (-f)	An Nmap option that sends scan packets in tiny IP fragments to bypass simple packet filters and intrusion detection systems.	A technique to evade basic network security controls by making it harder for firewalls to reassemble and inspect the packets.

Detailed Analysis

1. DNS Enumeration and Zone Transfer

Active information gathering often begins with DNS enumeration, a process of extracting details about a domain's DNS configuration. This can reveal critical information such as IP addresses, server names, and even the specific functionalities of various servers. Tools like `host` and `DNS lookup` are commonly used for this purpose.

- **Name Server Enumeration:** To identify the name servers associated with a domain, the `host` command can be used with the `-t ns` option.

```
host -t ns microsoft.com
```

This command queries for the name server records, providing a list of DNS servers responsible for the domain.

- **Mail Server Enumeration:** Similarly, to find mail exchange (MX) servers for a domain, the `host` command is used with the `-t mx` option.

```
host -t mx microsoft.com
```

This helps in identifying the mail infrastructure, which can sometimes be a target for specific attacks. For example, `microsoft.com` mail might be handled by `microsoft.com.mail.protection.outlook.com`.

- **DNS Zone Transfer:** A zone file contains a comprehensive list of all DNS names configured for a particular zone. Ideally, zone transfers should be restricted to authorized secondary DNS servers only. However, misconfigurations are common, allowing unauthorized parties to request and receive a copy of the zone file. This can provide a complete map of the domain's internal network.

To attempt a zone transfer, the `host` command with the `-l` option is used, specifying the domain and a known name server.

```
host -l nptel.ac.in ns1.nptel.ac.in
```

If the transfer fails, it indicates that permissions are correctly configured, preventing unauthorized access to the zone file.

2. Scanning Techniques with Nmap

Scanning is the next logical step in active reconnaissance, where an attacker or ethical hacker actively probes a target to identify vulnerabilities. Various types of scans exist, each designed to uncover specific information. Nmap is a versatile tool widely used for these scanning activities.

- **Types of Scans:**

- **Network Scan:** Detects live hosts on a network.
- **Port Scan:** Identifies open ports on a host.
- **Version/Service Scan:** Determines the software and its version running on specific ports.
- **OS Scan:** Detects the operating system of the target.
- **Vulnerability Scan:** Identifies weaknesses in computer systems, networks, or applications.

- **Nmap Scan Options:**

- **Network Scan (Host Discovery):** To find all live hosts within a network range, the `-sP` option is used.

```
nmap -sP 192.168.0.0/24
```

This command scans the entire subnet (e.g., 192.168.0.0 to 192.168.0.255) to identify active devices, including their IP and MAC addresses.

- **Port Scan:** To scan a specific range of ports on a target IP address, the `-p` option is used.

```
nmap -p 1-1000 192.168.0.106
```

This example scans ports 1 through 1000 on the host 192.168.0.106, revealing open ports and the services running on them.

- **Service/Version Scan:** To determine the exact version of a service running on a port, the `-sV` option is employed.

```
nmap -sV -T4 192.168.0.106
```

This command, combined with a timing template, provides detailed service information, such as "Microsoft Windows RPC" for port 135.

- **Stealth Scan (SYN Scan):** The `-sS` option initiates a TCP connection but never completes the three-way handshake, making it less conspicuous.

```
nmap -sS -T4 -p 1-1000 192.168.0.106
```

This scan type is designed to evade detection by some firewalls and intrusion detection systems.

- **TCP Connect Scan:** The `-sT` option performs a full TCP connection, which is more detectable but often gathers more reliable information.

```
nmap -sT -T4 -p 1-1000 192.168.0.106
```

This scan completes the standard TCP handshake, making it visible in target logs.

- **UDP Scan:** The `-sU` option is used to scan UDP ports. Unlike TCP, UDP scans expect replies from closed ports, as open UDP ports often do not respond.

```
nmap -sU -p 53 192.168.0.106
```

This attempts to identify UDP services, such as DNS (port 53).

- **ACK Scan:** The `-sA` option sends ACK packets to determine if a TCP port is filtered or unfiltered by a firewall. It does not determine if a port is open or closed.

```
nmap -sA -p 1-1000 192.168.0.106
```

This helps in mapping firewall rules, showing which ports are being actively filtered.

- **OS Detection:** The `-O` option attempts to determine the operating system of the target host.

```
nmap -O 192.168.0.106
```

This can reveal details like "Microsoft Windows" or "Linux with kernel 2.6".

- **Aggressive Scan:** The `-A` option combines OS detection, version detection, script scanning, and traceroute.

```
nmap -A -T4 192.168.0.106
```

This provides a comprehensive overview, including common services, their versions, and the operating system.

- **Bypassing Firewalls (No Ping Scan):** If a firewall blocks ping requests, the `-Pn` option can be used to skip the host discovery phase and assume the host is online.

```
nmap -Pn 192.168.0.106
```

This ensures Nmap proceeds with port scanning even if ICMP pings are blocked.

- **Packet Fragmentation:** The `-f` option fragments IP packets into smaller pieces, potentially bypassing simple packet filters or intrusion detection systems that don't reassemble fragments.

```
nmap -f 192.168.0.106
```

Each instance of `-f` adds 8 bytes to the maximum fragmented data size, sending typical TCP packets in multiple tiny fragments.

3. Understanding Port States

During scanning, Nmap reports various states for ports, each indicating a different interaction with the target:

- **Open:** The port is actively responding to incoming connections, indicating a service is listening on it.
- **Closed:** The port actively responds to a probe but has no service running. This often means no firewall is filtering traffic to that port.

- **Filtered:** A firewall or other network device is preventing Nmap from determining if the port is open or closed.
- **Unfiltered:** Nmap can access the port but cannot determine if it's open or closed. This state is common with ACK scans.
- **Open|Filtered:** Nmap believes the port is either open or filtered but cannot definitively determine which state it is in.
- **Closed|Filtered:** Nmap believes the port is either closed or filtered but cannot definitively determine which state it is in.

4. Nmap Timing Templates and Output Options

Nmap offers timing templates to control the speed and aggressiveness of scans, balancing between speed, network impact, and stealth. These are specified with the `-T` option, followed by a number (0-5) or a name.

- **Timing Templates:**

- `T0` (Paranoid): Extremely slow, designed for IDS evasion.
- `T1` (Sneaky): Very slow, also for IDS evasion.
- `T2` (Polite): Slows down scans to use less bandwidth and target resources.
- `T3` (Normal): The default mode, balancing speed and resource usage.
- `T4` (Aggressive): Speeds up scans, assuming a fast and reliable network.
- `T5` (Insane): Extremely fast, sacrificing some accuracy for maximum speed, suitable for extraordinary fast networks.

- **Output Options:** Nmap provides various formats for saving scan results:

- **Normal Output (`-oN`):** Creates a plain text file, suitable for human review or as input for other programs.

```
nmap -oN scan.txt 192.168.0.106
```

- **XML Output (`-oX`):** Generates an XML file, ideal for programmatic parsing and integration with other applications.
- **Grepable Output (`-oG`):** Produces a format easily parsed by command-line tools like `grep`, `awk`, `sed`, and `diff`, commonly used by penetration testers for further investigation.
- **Script Kiddies Output (`-oS`):** A less formal output format, not typically used for professional penetration testing but can be fun for casual use.

Key Takeaways

- [] Active reconnaissance involves direct interaction with target systems to gather information.
- [] DNS enumeration uses tools like `host` to discover name servers and mail servers.
- [] Misconfigured DNS zone transfers can expose a complete network map.
- [] Nmap is a powerful tool for various scanning types, including network, port, service, and OS scans.
- [] Different Nmap scan types (Stealth, TCP Connect, UDP, ACK) offer varying levels of stealth and information depth.
- [] Nmap timing templates (`-T0` to `-T5`) allow control over scan speed and aggressiveness.
- [] Understanding port states (open, closed, filtered, unfiltered) is crucial for interpreting scan results.
- [] Nmap offers multiple output formats (`-oN` , `-oX` , `-oG`) for different analysis and reporting needs.
- [] Techniques like `-Pn` (no ping scan) and `-f` (packet fragmentation) can be used to bypass basic firewall rules.
- [] Aggressive scans (`-A`) combine multiple information-gathering techniques for a comprehensive overview.

Conclusion

Active information gathering, through techniques like DNS enumeration and various Nmap scans, forms the bedrock of any robust cybersecurity assessment. By systematically probing target systems and networks, ethical hackers can uncover critical details about their infrastructure, identify open ports, running services, operating systems, and potential vulnerabilities. The ability to interpret port states, utilize different scan types for specific purposes, and manage scan aggressiveness through timing templates are indispensable skills. Furthermore, understanding how to bypass basic security measures like firewalls and how to format scan outputs for further analysis highlights the practical utility of these tools. Mastering these active reconnaissance methods empowers security professionals to proactively identify and mitigate risks, ultimately strengthening an organization's digital defenses against sophisticated threats.